

AI Risk Register Template – Universal Startup Version

A reusable, NIST AI RMF-aligned tool for tracking AI-specific risk across any startup's product lifecycle regardless of industry.

Problem Statement

Risk register templates built around a single vertical (fintech, e-commerce, healthtech) are useful as worked examples but hard to reuse, a startup building a completely different kind of AI product ends up stripping out irrelevant rows and guessing at what to replace them with. The risks that actually cause AI incidents, though, are mostly *pipeline-level*, not industry-level: undocumented training data, no audit trail, an unmanaged vendor relationship, silent model drift, no human override on a high-stakes decision. Those failure modes look identical whether the AI feature ranks leads, screens resumes, or recommends products. This version strips out the vertical-specific framing and keeps the register organized around those universal failure patterns, so any product team can drop it in and adapt the specifics without redesigning the structure.

In my experience running AI governance for an enterprise SaaS company's AI-integrated modules, the industry context matters far less than people assume when you're deciding *what to track*, it matters a lot when you're deciding *how severe it is*. This template keeps that distinction explicit.

README - What This Is, Why You Need It, How to Use It

What it is: A 13-column risk register tracking AI-specific risk from data sourcing through deployment through post-launch monitoring, mapped to NIST AI RMF's four functions (Govern, Map, Measure, Manage) and scored on a 5×5 likelihood/impact matrix. This version uses eight universal risk patterns as worked examples instead of a single industry scenario, so it applies whether you're building a recommendation engine, a scoring tool, a support chatbot, or an internal AI copilot.

Why every AI product team needs one, regardless of vertical: The risks that cause real incidents, a leaked training dataset, an unaudited vendor, a model that's quietly stopped working correctly, an AI decision nobody can explain after the fact, aren't industry problems. They're AI pipeline problems. A generic feature bug tracker doesn't catch them because they don't look like bugs until they're incidents. This register exists to name them before that happens.

How to use it: Copy the table structure below. Delete the eight worked examples once you understand the pattern each one represents, and replace them with your own, one row per new model, new data source, new AI vendor, or new AI-generated customer-facing output. Score every row using the rubrics in Sections 4–5. Review Critical/High rows weekly, everything else monthly.

1. Full Risk Register - Universal Worked Examples

These eight rows represent risk patterns common to nearly any AI-integrated product, independent of industry. Each is written generically enough to adapt directly, swap "AI feature" for your actual feature name and the risk still holds.

Risk ID	Risk Description	NIST Function	Risk Category	AI System / Module	Likelihood (1–5)	Impact (1–5)	Risk Score	Risk Tier	Owner	Mitigation / Control Action	Status	Next Review
R-001	Training or fine-tuning data includes personal or sensitive user data with no documented consent basis or provenance record	Map	Data Governance	Model Training Pipeline	3	5	15	Critical	Data/ML Lead	Build a data provenance log for every training dataset; confirm consent basis before any dataset is used for training	Open	Weekly
R-002	End users interact with AI-generated content or decisions with no disclosure that AI produced or influenced the output	Govern	Compliance	Customer-Facing AI Feature	3	4	12	High	Product, Legal	Add a visible AI-disclosure label wherever AI-generated or AI-influenced content reaches an end user	Open	Monthly
R-003	No audit log exists for AI-driven decisions that affect a user, so a decision can't be reconstructed or explained after the fact	Govern	Compliance	Decision-Support AI Feature	3	4	12	High	Eng Lead	Log every AI decision: inputs, output, model version, timestamp; retain per data retention policy	Open	Monthly

Risk ID	Risk Description	NIST Function	Risk Category	AI System / Module	Likelihood (1–5)	Impact (1–5)	Risk Score	Risk Tier	Owner	Mitigation / Control Action	Status	Next Review
R-004	A third-party AI/model API vendor is integrated into the product with no signed Data Processing Agreement or documented data handling terms	Govern	Vendor / Compliance	Core AI Feature (vendor-dependent)	3	5	15	Critical	Legal, Procurement	Execute a DPA with every AI vendor before production use; log vendor, data shared, and retention terms in a vendor register	Open	Monthly
R-005	Model performance degrades over time as real-world inputs shift from training conditions, with no monitoring in place to detect it	Manage	Model Risk	Any Production AI Model	3	3	9	High	ML Lead	Establish a monitoring benchmark and alert threshold for output quality/accuracy drift; review monthly	Open	Monthly
R-006	No fairness or bias testing has been run across user segments (e.g., demographic, geographic, or behavioral groups) before or after launch	Measure	Bias / Fairness	Any User-Facing AI Feature	3	4	12	High	Data Science	Run a segment-level output distribution audit pre-launch and quarterly thereafter; document and remediate disparities	Open	Quarterly

Risk ID	Risk Description	NIST Function	Risk Category	AI System / Module	Likelihood (1–5)	Impact (1–5)	Risk Score	Risk Tier	Owner	Mitigation / Control Action	Status	Next Review
R-007	Employees use unsanctioned public AI tools with company or customer data because no approved internal AI toolset exists ("shadow AI")	Govern	Data Governance	Org-wide	4	4	16	Critical	IT Security, Compliance	Publish an approved-AI-tools policy; deploy data-loss-prevention controls; run team awareness training	Open	Weekly
R-008	A high-stakes AI-driven decision (affecting access, pricing, ranking, or eligibility) ships with no human review or override mechanism	Manage	Governance / Operational	High-Stakes AI Feature	3	5	15	Critical	Product, Compliance	Require a human-in-the-loop review path for any decision above a defined stakes threshold before full automation is allowed	Open	Weekly

Monday morning action: Before you customize this table, walk your current AI features and check off which of these 8 patterns already apply to something you've shipped. Most teams find at least 3 apply immediately, those become your first real rows, not the templates above.

2. Likelihood Scoring Rubric (1–5)

Score	Label	Definition
1	Rare	Would require an unusual combination of failures; no precedent in this system or comparable systems
2	Unlikely	Technically possible, no evidence of occurrence yet; would require a specific edge case
3	Possible	Plausible under normal operating conditions; similar issues have occurred in comparable AI systems
4	Likely	Has already occurred at least once, or occurs under conditions the system regularly encounters
5	Almost Certain	Occurring now, or will occur within the next release cycle without intervention

3. Impact Scoring Rubric (1–5)

Score	Label	Definition
1	Negligible	Internal-only inconvenience; no customer or regulatory exposure
2	Minor	Isolated customer complaint or minor rework; no external reporting obligation
3	Moderate	Visible customer harm (wrong output, degraded trust) or minor data governance gap; fixable without disclosure
4	Major	Regulatory exposure, material customer harm, or reputational damage requiring disclosure
5	Severe	Legal liability, regulatory penalty, breach notification obligation, or harm at scale across multiple users

4. 5×5 Risk Scoring Matrix

Risk Score = Likelihood × Impact.

Likelihood ↓ / Impact →	1 (Negligible)	2 (Minor)	3 (Moderate)	4 (Major)	5 (Severe)
5 (Almost Certain)	5 – Medium	10 – High	15 – Critical	20 – Critical	25 – Critical
4 (Likely)	4 – Low	8 – Medium	12 – High	16 – Critical	20 – Critical
3 (Possible)	3 – Low	6 – Medium	9 – High	12 – High	15 – Critical
2 (Unlikely)	2 – Low	4 – Low	6 – Medium	8 – Medium	10 – High
1 (Rare)	1 – Low	2 – Low	3 – Low	4 – Low	5 – Medium

Zone definitions:

- **Low (1–4):** Log it, no immediate action required. Review quarterly.
- **Medium (5–9):** Assign an owner and a mitigation plan; review monthly.
- **High (10–14):** Mitigation must be in progress before next release; review weekly.
- **Critical (15–25):** Blocks release of the affected feature until mitigated or explicitly risk-accepted by a named senior owner. Review weekly, no exceptions.

Monday morning action: Agree, in writing, that Critical-tier risk blocks release, before you need to enforce it under pressure from a launch deadline. A rule adopted mid-crisis is a rule nobody trusts.

5. Adapting This Template to Your Product

This register is deliberately industry-agnostic, but a generic template is only useful once you make it specific to what you're actually building. Three steps to localize it:

1. **Replace the "AI System / Module" column with your real feature names.** R-001 through R-008 are patterns, not your risks; once you've confirmed a pattern applies, rewrite the description with your actual feature, actual data source, and actual vendor.
2. **Re-score likelihood and impact against your real user base and regulatory exposure.** A B2B tool with 50 enterprise customers and a consumer app with 2 million users score identically on the rubric structure but very differently on impact; don't inherit the scores above, recalculate them.
3. **Add industry-specific rows on top of the universal eight.** The eight patterns here are a floor, not a ceiling; a healthtech product needs additional rows for clinical decision liability, a fintech product needs credit-decision explainability rows, a hiring product needs adverse-impact testing rows. This template gives you the structure; your industry gives you the additions.

6. India-Specific Risk Considerations

Five risk categories frequently missing from Western-authored risk register templates, material for any Indian AI company or any global company processing Indian users' data, regardless of industry:

- ☐ **DPDP Act cross-border transfer basis undocumented.** AI pipelines that route data through foreign inference infrastructure often lack a documented legal basis for the transfer; build a data flow map before assuming your privacy policy covers it.
- ☐ **Significant Data Fiduciary (SDF) threshold blindness.** Fast-scaling companies can cross the volume/sensitivity thresholds that trigger SDF obligations (mandatory DPO, impact assessments, independent audits) without tracking it. This should be a standing quarterly review item, not a one-time check.
- ☐ **Consent architecture built for GDPR, retrofitted badly for DPDP.** DPDP Act consent requirements differ from GDPR in structure; purpose limitation, notice-language accessibility, and withdrawal mechanisms are commonly missed when a GDPR flow is assumed to transfer directly.
- ☐ **No Grievance Officer / Consent Manager pathway for AI-driven decisions.** If an AI system informs a decision that affects a Data Principal, there needs to be a documented path for that person to contest it; most AI features ship without one because it was never treated as a feature requirement.
- ☐ **Vendor risk underestimated because the vendor is "just an API."** Companies building on foundation model providers often treat the relationship as a technical integration rather than a data processing relationship requiring a DPA, subprocessor disclosure, and residency terms.

7. Integrating the Register into Agile Sprints

- **Sprint planning:** Any story introducing a new model, new data source, or new AI-generated output gets a register entry before the story is pointed. No entry, no estimation.
- **Definition of Done:** For AI-touching stories, "risk register entry created/updated and reviewed by [owner]" is a DoD line item, same tier as passing tests.
- **Sprint review:** Spend five minutes on any Critical or High risk that changed status. This is a standing agenda item inside the existing ceremony, not a separate governance meeting.
- **Retro:** An incident that wasn't on the register beforehand is a retro topic; the register failed to catch something, and that gap is worth understanding on its own.

Monday morning action: Open your current sprint board. Count how many AI-touching stories have zero corresponding risk register entry. That number is your actual governance debt.

Limitations and Future Work

A universal template trades specificity for reusability; the eight worked examples here are real failure patterns, but they're deliberately abstracted, which means they carry less evidentiary weight in an interview than a register built from a specific, lived scenario. Anyone using this should treat Section 1 as a starting structure to be overwritten with real rows within the first week of use, not as a finished artifact. The scoring rubrics are ordinal judgment calls, not statistical models; two reasonable reviewers can score the same risk differently, and that's worth surfacing in team discussion rather than treating as a flaw to eliminate. The template also doesn't yet capture risk *interaction effects* (e.g., a data governance gap and a vendor risk compounding each other) ; a future version should add lightweight risk dependency mapping and a companion incident log that traces which realized incidents map back to a register entry that was known but under-mitigated, versus incidents that reveal a genuinely new risk category the register missed.